CRA Scope & Classifier

Een open, controleerbare beslisassistent voor toepasselijkheid en productclassificatie onder de EU Cyber Resilience Act

Geconsolideerd voorstel: marktonderzoek, doelgroepen, rechtsbronnen, rule engine, UX, AI-ondersteunde studie, agentinteroperabiliteit, statische architectuur, SWOT en roadmap.

Status: werknaam en onderzoeksvoorstel; geen gevalideerde juridische classificatieservice.

Managementsamenvatting

Doel: bedrijven en ontwikkelaars betrouwbaar laten beantwoorden (1) valt een concreet product en marktactiviteit onder de CRA? en (2) welke classificatie geldt: Default, belangrijk Class I, belangrijk Class II of Critical? De tool moet onderbouwen waarom, onzekerheden tonen en onjuiste schijnzekerheid vermijden. Dit is uitdrukkelijk GEEN volledige CRA-compliance-, implementatie- of checklisttool.

Aanbevolen ontwerp: static-first browserapp met één open, deterministische regelengine, een universeel assessment ongeacht sector, gevalideerde juridische brondekking, lokale privacyvriendelijke verwerking, JSON/PDF-export en optionele CLI/lokale MCP-adapter. AI/LLM uitsluitend voor onderzoek, taalondersteuning of het voorbereiden van feitelijke invoer; niet voor de uiteindelijke juridische beslissing.

Beslissing	Voorgestelde keuze
Positionering	CRA-toepasselijkheid en classificatie, niet algemene compliance.
Doelgroepen	Rol × leveringsvorm × sectorcontext; geen harde doelgroepafhankelijkheid.
Beoordeling	Vierwaardige feiten: ja / nee / onbekend / tegenstrijdig.
Technologie	Statische TypeScript-app + versiebeheerbare regels en testcases.
Uitbreidbaarheid	Machineleesbare assessments, npm/CLI, optioneel lokale MCP.
Vertrouwen	Bronverwijzingen, audittrail, menselijke validatie, disclaimer.

1. Scope, ambitie en positionering

De CRA is veel breder dan alleen de vraag of een product onder de wet valt: ook essentiële cybersecurityvereisten, kwetsbaarhedenbeheer, conformiteitsbeoordeling, CE-markering en markttoezicht zijn belangrijk. Juist daarom moet de naam en propositie geen volledig complianceplatform suggereren.

De kernbelofte: “Is mijn product onderworpen aan de CRA, welke klasse geldt, en waarom?” Een resultaat bevat relevante feiten, rol en productgrens, doorlopen regels, exacte juridische verwijzingen, onbeantwoorde vragen en versie-informatie.

Naamstrategie

Werknaam	Voordelen	Risico / beoordeling
CRA Scope & Classifier	Expliciete afbakening; begrijpelijk voor bedrijven	Sterk als functionele naam of tagline.
CRA Compass	Kort en toegankelijk	Kan bredere CRA-begeleiding suggereren; ondertitel nodig.
CRA Applicability & Classification Navigator	Juridisch precies	Lang, maar bruikbaar als officiële projectomschrijving.
CRA ScopeCheck	Makkelijk te onthouden	Benadrukt toepasselijkheid, minder classificatie.
OpenCRA	Open-source-associatie	Te ruim: klinkt als algemene CRA-tool of organisatie.

Voorlopige aanbeveling: gebruik “CRA Scope & Classifier” als werknaam, met “An explainable CRA applicability and classification tool” als Engelstalige ondertitel. Toets naam, domein en merkenrecht vóór publieke lancering. Geen claim van EU-officiële status.

2. Juridisch fundament en begrenzing

Primaire bronnen: Regulation (EU) 2024/2847, vooral art. 2–3 (scope/definities), art. 7–8 (important/critical), art. 13 en 17–22 (marktdeelnemers), art. 32 (conformiteitsbeoordeling), Annex III/IV; en Uitvoeringsverordening (EU) 2025/2392 met bindende technische beschrijvingen. Raadpleeg daarnaast officiële Commissie-FAQ en de implementatierichtsnoeren van 27 juli 2026. De officiële FAQ is een levende bron en wordt geactualiseerd.

Bronhiërarchie: (1) bindende EU-rechtsteksten en wijzigingen, (2) officiële, niet-bindende Commissie-uitleg, (3) gedocumenteerde expertinterpretatie, (4) onafhankelijke websites en gebruikersvoorbeelden. Toon het gezag van iedere bron zichtbaar. Productnaam, sector of ingebouwde component zijn op zichzelf nooit sluitend bewijs voor een klasse.

Beoordelingsstatussen: OUT_OF_SCOPE, IN_SCOPE_DEFAULT, IN_SCOPE_CLASS_I, IN_SCOPE_CLASS_II, IN_SCOPE_CRITICAL, NEEDS_INFORMATION, NEEDS_EXPERT_REVIEW. Een definitieve DEFAULT-uitkomst is alleen toegestaan als de toepasselijke hogere categorieën daadwerkelijk getoetst en uitgesloten zijn. Een juridische scopevraag die nog openstaat blokkeert een definitieve classificatie.

3. Doelgroepselectie zonder willekeur

Gebruik geen afzonderlijke rechtslogica voor industrie, smart building, software of consumentenelektronica. Leid behoeften af via drie onafhankelijke assen: (A) marktrol, (B) aangeboden product/dienst, (C) gebruikscontext. Hiermee vallen ook hybride bedrijven en onbekende sectoren onder de universele assessmentflow.

Dimensie	Voorbeelden	Gebruik in de tool
Marktrol	Fabrikant, importeur, distributeur, integrator, open-source steward	Rolverplichtingen, verantwoordelijkheden, vervolgvraag.

Dimensie	Voorbeelden	Gebruik in de tool
Leveringsvorm	Hardware, firmware, standalone software, component, cloudbackend, SaaS, maatwerk	Scope en productgrens bepalen.
Context	Industry, smart buildings, enterprise, consumer, medisch, automotive	Herkenbare woorden en voorbeelden; geen rechtsregel.

Prioriteer concrete persona's met een transparante score: CRA-exposure, volume van behoefte, verwachte juridische complexiteit, bereikbaarheid voor interviews, waarde van besliszekerheid en diversiteit van productgevallen. Valideer deze scores via interviews en analyse van publieke vragen, niet via intuïtie.

De "Other"-garantie

"Anders / Other" moet dezelfde juridische volledigheid bieden als elk voorgeselecteerd profiel. Profielen verschillen enkel in startvragen, voorbeelden, terminologie en navigatie. De universele route behandelt alle scope-eisen en alle Annex III/IV-categorieën. Leg met tests vast dat profielkeuze bij identieke feiten nooit een andere uitkomst oplevert.

4. Beslislogica en onzekerheidsmodel

Volgorde: product en componentgrens → markttoegang en commerciële context → connectiviteit en wettelijke uitzonderingen → economische rol → inventaris kernfuncties → technische categorieën Annex IV en Annex III → klasse en resterende onzekerheden → begrijpelijk bewijsrapport. Elk stadium kan de vereiste volgende vragen bepalen.

Een regel is niet enkel een IF/THEN. Bewaar: regel-ID; exact artikel/annex/onderdeel; juridische tekstversie; feitelijke voorwaarden; uitzonderingen; positieve en negatieve voorbeelden; alternatieve interpretatie; prioriteit; relevante datapoints; testcases; reviewer; validatie- en vervaldatum.

Antwoordstatus	Interpretatie	Verplichte behandeling
TRUE	Expliciet bevestigd feit	Regel kan worden toegepast, herkomst bewaren.
FALSE	Expliciet ontkend feit	Mag een noodzakelijke voorwaarde uitsluiten.
UNKNOWN	Nog geen onderbouwd feit	Gerichte vervolgvraag, nooit impliciet FALSE.
CONFLICTING	Tegenstrijdig bewijs	Waarschuwing + correctie/review vóór einduitkomst.

Behandel regelconflicten en meerdere kernfunctionaliteiten expliciet. Toon niet alleen het resultaat maar ook niet-gematchte kandidaatcategorieën met de reden van uitsluiting. Leg op productniveau vast welke functionaliteit een feature is en welke bedoeld is als kernfunctie. De uitvoeringsverordening 2025/2392 is bepalend voor de technische categoriegrenzen.

5. Gebruikssituaties voor validatie

Casus	Belangrijkste vraag	Indicatieve hypothese
Huisdiercamera voor gedragsanalyse	Security camera versus dierenobservatie	Waarschijnlijk Default mits geen security-kernfunctie.
Videodeurbel voor inbraakdetectie	Smart home security (Annex III, Class I, 17)	Class I aannemelijk.
Tandenborstel met camera	Mondhygiëne versus medische bestemming	Default of wettelijke medische uitzondering; onderzoek.
PLC of industriële gateway	Functie versus sectorlabel	Niet automatisch Class II.
HVAC / toegangscontrole	Smart building is geen juridische klasse	Per kernfunctie evalueren.
Standalone SaaS versus IoT-backend	Remote data processing als productonderdeel	Scope verschilt naar productrelatie.
Software op maat / OEM / integratie	Wie brengt welk product op de markt?	Fabrikantrol en productgrens moeten worden vastgesteld.
Commerciële versus niet-commerciële OSS	Activiteit en stewardrol	Speciale scope- en rolroute.

Deze uitkomsten zijn uitsluitend voorgestelde testhypothesen en moeten tegen de volledige wettelijke voorwaarden worden gereviewd. Bouw minstens 50 representatieve casussen en extra “minimal pairs”: identieke producten die op één juridisch relevant feit verschillen.

6. Aanvullende AI/LLM-onderzoeksstudie — vóór bouw

AI mag het onderzoek naar lacunes aanzienlijk versnellen. Gebruik LLM’s om publieke bronnen te structureren en kandidaatvragen, taxonomieën en grensgevallen te genereren. Laat juridisch relevante conclusies pas na broncontrole en menselijke review toe in de regelcatalogus.

Werkpakket	Methode	Resultaat
WP1 Juridische kenniskaart	Regel-/uitzonderingskandidaten extraheren uit EU-bronnen	Brongekoppelde kandidaatregels en open interpretaties.
WP2 Producttaal & markt	Productbeschrijvingen, termen en synoniemen groeperen	Neutrale taxonomie en begrijpelijke vragen.
WP3 Gebruikersbehoeften	FAQ’s, forums, interviews en publieke feedback	Geprioriteerde job-to-be-done en obstakels.
WP4 Benchmark	Tools op vaste casussen doorlopen en vergelijken	Geverifieerde gap-analyse, geen aannames over code.
WP5 Edge cases	LLM genereert tegenvoorbeelden/minimal pairs	Menselijk beoordeelde regressieset.
WP6 UX & talen	Comprehension tests, meertalige proefversies	Vragen die voor niet-juristen begrijpelijk blijven.
WP7 Rules-as-Code	Onderzoek formaliseringsmethoden en kwaliteitscriteria	Keuze regelmodel en governance.

Onderzoeksprotocol: bron-URL, auteur, publicatiedatum, wetversie, toegangsdatum, licentie en betrouwbaarheid per bevinding vastleggen. Strikte scheiding tussen letterlijk citaat, interpretatie, hypothese en geverifieerde testcase. Publiceer geen vertrouwelijke bedrijfsdata in externe LLM-tools; anonymiseer interviews en respecteer auteursrecht en gebruiksvoorwaarden.

7. Leren van bestaande tools en kennisinitiatieven

Cyberresilienceact.eu is een onafhankelijke website, geen door de EU aangeboden officiële tool. De Classification Finder laat gebruikers categorieën kiezen; de FAQ biedt toegankelijke thematische antwoorden. Sterkte: snelle kennismaking. Te onderzoeken beperkingen: vraagt classificatiekennis van gebruikers, zichtbaar bewijs van categorie-uitsluiting, expliciete UNKNOWN/CONFLICTING, product-/rolgrenzen en reproduceerbare audittrail. Dit zijn te toetsen hypotheses, geen bewezen tekortkomingen van alle onderdelen van de website.

Asphalia heeft een bredere CRA-assessmentopzet. Zolang de interactieve logica niet volledig en herhaaldelijk is getest, kunnen we juridische juistheid niet bevestigen. Vergelijk beide tools met dezelfde cases en documenteer schermen, ingevoerde feiten, uitkomsten, brondekking, onzekerheidsbehandeling en datum.

De ORC Working Group CRA Hub bundelt officiële FAQ's en richtsnoeren; bruikbaar voor bronvondst en open kwesties, maar vervangt geen eigen validatie. Rules-as-Code-referenties: Catala (tekst-/codekoppeling), LegalRuleML (juridische regels en normativiteit), OpenFisca (versiebeheer/testbaarheid), en OECD Law as Code (governance en gezaghebbende bronkoppeling). Onderzoek hergebruik en licenties, maar kies geen zware formele taal vóór een praktische proef.

8. Technische opties: static-first

Aanbevolen: statische webapp op bijvoorbeeld GitHub Pages of Cloudflare Pages; TypeScript-rule-engine uitgevoerd in de browser; JSON/YAML-regels gebundeld in de release; lokale opslag optioneel; PDF en JSON-export client-side; optionele offline PWA met zichtbare regelversie en verversingswaarschuwing. Geen login en geen centrale opslag in MVP.

Variant	Voordeel	Nadeel / beslissing
Static-first browser	Privacy, goedkoop, eenvoudige self-hosting, reproduceerbaar	Aanbevolen voor MVP.
Publieke REST-backend	Remote API en centrale analytics/accounts	Meer beveiliging, privacy, kosten; niet nodig voor MVP.
CLI/npm library	Lokale automatisering en integraties	Gedeelde regelengine; in vroeg ontwerp voorzien.
Lokale MCP-server	Agent kan vragen opvragen en lokaal evalueren	Geen centrale backend; installatie nodig.
Remote MCP via serverless	Agents op afstand kunnen rechtstreeks aanroepen	Extra operationeel oppervlak; fase na MVP.

Belangrijk: een louter statische website kan zelf geen inkomende remote MCP- of POST-API-verzoeken afhandelen. Een lokaal geïnstalleerde MCP-adapter of serverless gateway is een afzonderlijke component. De regelengine moet pure functies gebruiken, zonder externe AI, netwerkcalls of geheime backendregels.

9. Agent-ready, maar geen AI in de classificatie

Ontwerp een gestructureerde assessment-API: create_assessment, get_next_questions, submit_answers, evaluate, explain, export. Een LLM-agent mag productdocumentatie samenvatten en conceptantwoorden aanleveren; herkomst wordt gemarkeerd als USER_CONFIRMED, DOCUMENT_SUPPORTED, MODEL_INFERRED of UNKNOWN. MODEL_INFERRED mag niet stilzwijgend beslissende feiten bevestigen.

Beveilig tegen prompt injection in geüploade documentatie, behandel geheime productgegevens minimaal, geef agents least-privilege scopes, log relevante wijzigingen, vermijd automatische publicatie van assessmentdata en behoud menselijke bevestiging voor materiële onduidelijkheden. Maak uitkomsten machineleesbaar inclusief rule_set_version, law_version, evidence, missing_information en reasons.

10. UX: waarom bedrijven dit zullen gebruiken

Twee trajecten: (A) snelle, expliciet voorlopige precheck met beperkt aantal vragen; (B) diepgaand assessment met volledige juridisch relevante dekking. Bied steeds “Waarom vragen we dit?”, voorbeeld/tegenvoorbeeld, exacte EUR-Lex-link en mogelijkheid om terug te gaan. Vraag om feiten, niet om zelf een Annex-categorie te kiezen.

Rapport: productgrens, verstrekte feiten en herkomst, economische rol, CRA-scope, classificatie met overwegingen, geëvalueerde kandidaatregels, onzekerheden, juridische bronversies, assessmentdatum, disclaimer. Geef aan wat de tool NIET beoordeelt: geen gedetailleerde Annex I-implementatiechecklist, geen conformiteitscertificaat, geen juridisch advies.

Succescriteria: percentage referentiecasussen correct; aantal foutieve definitieve beoordelingen; false-negative risico voor hogere klassen; aantal onbesliste beoordelingen; toegankelijkheid/readability; tijd tot een verdedigbare conclusie; aandeel gebruikers dat redenen begrijpt; terugkeer naar opgeslagen lokale assessments. Meet snelheid nooit ten koste van juridische kwaliteit.

11. Do’s en don’ts

DO	DON’T
Valideer elke regel tegen exacte bindende bron.	Een LLM of trefwoord rechtstreeks de klasse laten bepalen.
Gebruik TRUE/FALSE/UNKNOWN/CONFLICTING.	Ontbrekende feiten interpreteren als Nee.
Maak “Other” even volledig als begeleide routes.	Juridische dekking afhankelijk maken van sectorselectie.
Vermeld versie en motivering per uitkomst.	Schijnbaar officiële of gecertificeerde status suggereren.
Leg onopgeloste juridische interpretaties bloot.	Disclaimers gebruiken als alternatief voor kwaliteitszorg.
Test negatieve én positieve casussen.	Default toekennen zonder Annex III/IV uit te sluiten.

12. SWOT-analyse

Sterktes	Zwaktes
Reproduceerbare, controleerbare besluiten; open bronkoppeling; privacyvriendelijke statische uitvoering.	Juridische formalisering is duur; onderhoud van interpretaties; complexe productgrenzen niet altijd te automatiseren.

Kansen	Bedreigingen
Sterke vraag naar begrijpelijke CRA-scope; integratie via CLI/MCP; open testcases en community-review; herbruikbare Rules-as-Code-methodiek.	Foute conclusies en reputatierisico; frequente guidance-updates; alternatieve tools; onduidelijke aansprakelijkheid; vertrouwelijke productdata.

13. Kwaliteit, juridische verantwoordelijkheid en disclaimer

Governance: juridisch reviewer voor iedere regelwijziging, technische reviewer voor uitvoering, openbare changelog, verplichte regressietests, updatebeleid, intake voor foutmeldingen, gedocumenteerde policy voor wetwijzigingen en zichtbare release-/rechtversies. “Geen juridisch advies” is een noodzakelijke maar ontoereikende maatregel; zorgvuldigheid is nog steeds vereist.

Conceptclausule — juridisch te laten nakijken

“Deze toepassing is een informatief hulpmiddel voor een voorlopige beoordeling van de toepasselijkheid en productclassificatie onder de EU Cyber Resilience Act. Zij verstrekt geen juridisch advies, geen bindende interpretatie, geen conformiteitsbeoordeling, geen certificering en geen garantie dat een product aan alle wettelijke vereisten voldoet. De uitkomst is afhankelijk van de juistheid en volledigheid van de ingevoerde gegevens en van de weergegeven versie van de rechtsbronnen en beslisregels. Gebruikers blijven verantwoordelijk voor hun eigen beoordeling en dienen bij twijfel een gekwalificeerde adviseur of bevoegde instantie te raadplegen. Voor zover toegestaan door toepasselijk recht worden de toepassing en inhoud verstrekt zonder garanties en is de aansprakelijkheid van aanbieders en bijdragers beperkt zoals nader bepaald in de toepasselijke gebruiksvoorwaarden. Niets hierin sluit aansprakelijkheid uit die wettelijk niet kan worden uitgesloten.”

Laat deze disclaimer, gebruiksvoorwaarden, licenties, privacyverklaring, aansprakelijkheidsgrenzen en toepasselijk recht toetsen door een bevoegde jurist. Gebruik geen absoluut “wij zijn nergens voor aansprakelijk”; zo’n stelling is juridisch niet betrouwbaar.

14. Roadmap met go/no-go poorten

Fase	Oplevering	Go/no-go
0. Discovery	Benchmark, doelgroepinterviews, LLM-studie, 50+ casussen, open juridische vragen	Minimale marktbehoefte en bronbasis bevestigd.
1. Legal rule pilot	Scope + enkele lastige Annex-categorieën in een formeel regelschema	Juridische review en tests slagen.
2. Core MVP	Volledige scope en Annex III/IV, Other,	Dekkings- en false-final metrics

Fase	Oplevering	Go/no-go
	browserflow, uitleg, exports	acceptabel.
3. Public beta	Meertaligheid, toegankelijkheid, PWA, feedback- en releaseproces	Kwaliteits- en juridische gate.
4. Integrations	npm/CLI, lokale MCP; pas later remote endpoint	Agentveiligheid en semantische parity aangetoond.

Niet in MVP: Annex I-implementatiechecklists, SBOM-generatoren, incidentmelding, juridische representatie, CE-certificering of volledige compliance-workflows. Deze kunnen later aparte modules zijn en moeten een andere positionering krijgen.

15. Open onderzoeksvragen en beslissingen

- Welke juridische beslispunten vereisen noodzakelijk menselijk oordeel (bv. kernfunctionaliteit, productgrens, substantial modification)?
- Welke doelgroepsegmenten leveren de meeste en meest diverse echte assessments op?
- Hoe toetsen we semantische gelijkheid van web, CLI en MCP bij identieke invoer?
- Welk minimumbewijs volstaat om een feit als bevestigd te registreren?
- Hoe worden rechtswijzigingen en FAQ-revisies opgenomen en oudere exports opnieuw beoordeeld?
- Welke licentie en governance versterken open review zonder aansprakelijkheid te onderschatten?
- Hoe beschermen we privacy, toegankelijkheid en meertalige juridische precisie zonder backend?

16. Bronnen en onderzoeksreferenties

EU CRA 2024/2847 — https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32024R2847

Technische productbeschrijvingen EU 2025/2392 — https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32025R2392

Commissie guidance, 27 juli 2026 — https://digital-strategy.ec.europa.eu/en/news/commission-publishes-new-guidance-support-businesses-implementation-cyber-resilience-act

ORC WG officiële CRA FAQ — https://cra.orcwg.org/faq/official/

ORC WG officiële guidance — https://cra.orcwg.org/official-guidance/

Onafhankelijke CRA classification finder — https://www.cyberresilienceact.eu/nl/classification.html

Onafhankelijke CRA FAQ — https://www.cyberresilienceact.eu/nl/faq.html

Asphalia assessment — https://cra.asphaliaconsulting.be/?lang=nl

OECD Law as Code consultatie — https://www.oecd.org/en/events/public-consultations/2026/07/consultation-on-the-digital-provision-of-law-towards-a-shared-reference-framework-for-law-as-code.html

Catala — https://github.com/CatalaLang/catala

OpenFisca — https://openfisca.org/

LegalRuleML — https://www.oasis-open.org/standard/legalruleml-core-specification-version-1-0-oasis-standard/